

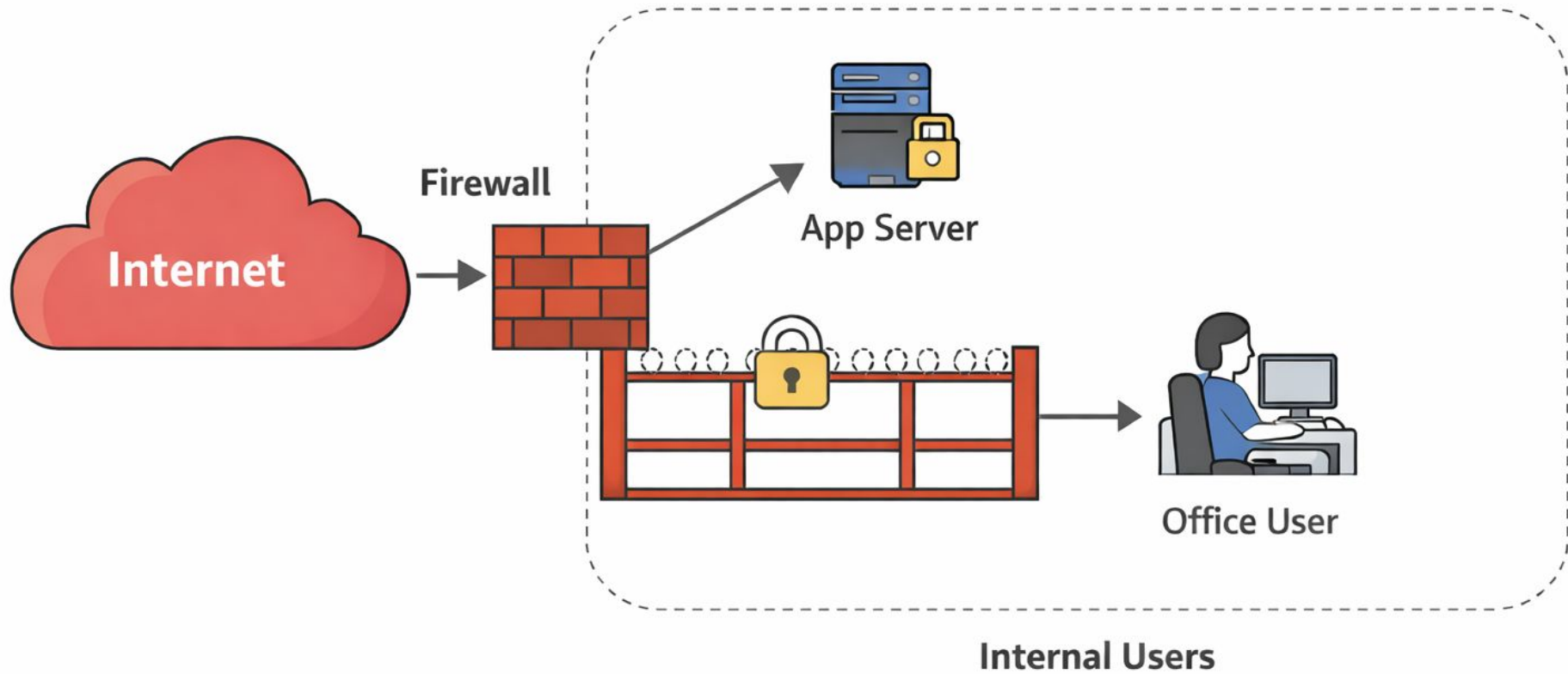
Von Perimeter zu Zero Trust: Motivation, Design und technische Hürden



Stephan Kraft
Open Source Community
Advocate & Business
Development, Red Hat

Höchst, 17.März 2026

The base: Perimeter-based Security



History (1)

- **2004: Jericho Forum**

- Founded 2004, merged with Open Group 2014
- Championed “de-perimeterization”

“De-perimeterization has happened, is happening, and is inevitable”

“Whereas boundary firewalls may continue to provide basic network protection, individual systems and data will need to be capable of protecting themselves.”

“All devices must be capable of maintaining their security policy on an **un-trusted network**”

History (2)

2007: "Vision for a Net-Centric, Service-Oriented DoD Enterprise"

"Black core enabling technologies that support end-to-end protection of information exchanged among users and services located anywhere in the target GIG. [...] A black core is a set of core components where all data traffic moving among these components is encrypted end-to-end. [...] Black core supports the evolution of the GIG from a system-high perimeter protection model to a transaction-based Enterprise IA protection model."

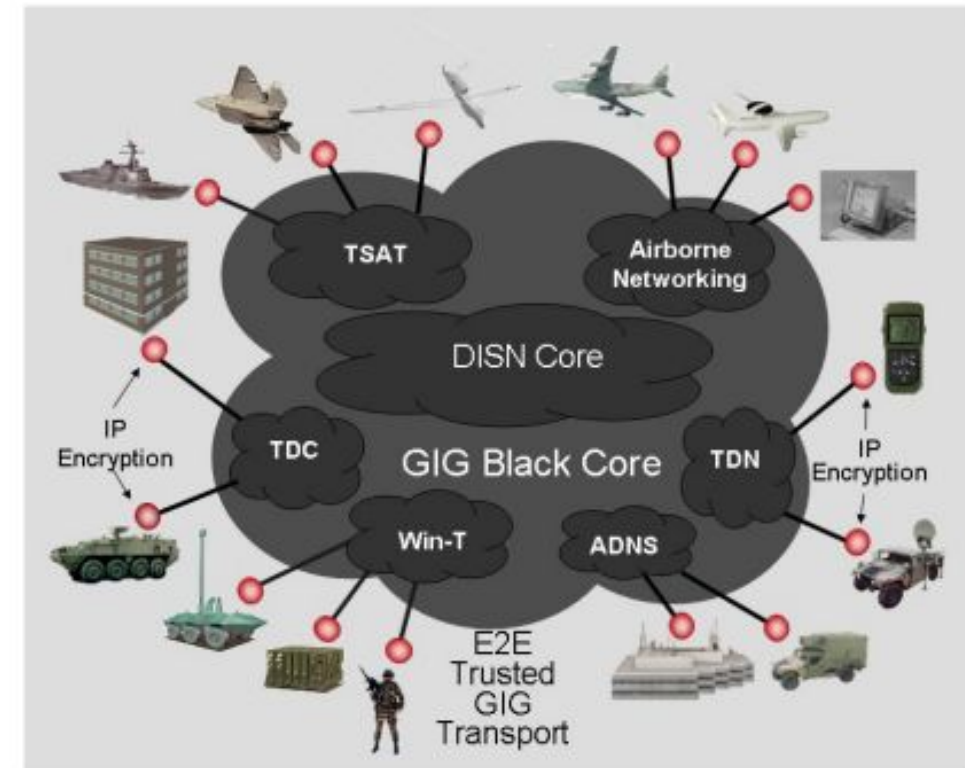


Figure 10 – Conceptual View of an E2E GIG with a Black Core

History (3)

- Zero Trust coined by John Kindervag in 2010 (while at Forrester):

<https://media.paloaltonetworks.com/documents/Forrester-No-More-Chevy-Centers.pdf>

Trust, but verify -> Never trust, always verify

- Zero Trust Architecture (NIST Special Publication 800-207), 2020

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>

What is Zero Trust?

Zero trust architecture is an end-to-end approach to enterprise resource and data security that encompasses identity (person and non-person entities), credentials, access management, operations, endpoints, hosting environments, and the interconnecting infrastructure.

Source: <https://csrc.nist.gov/pubs/sp/800/207/final>



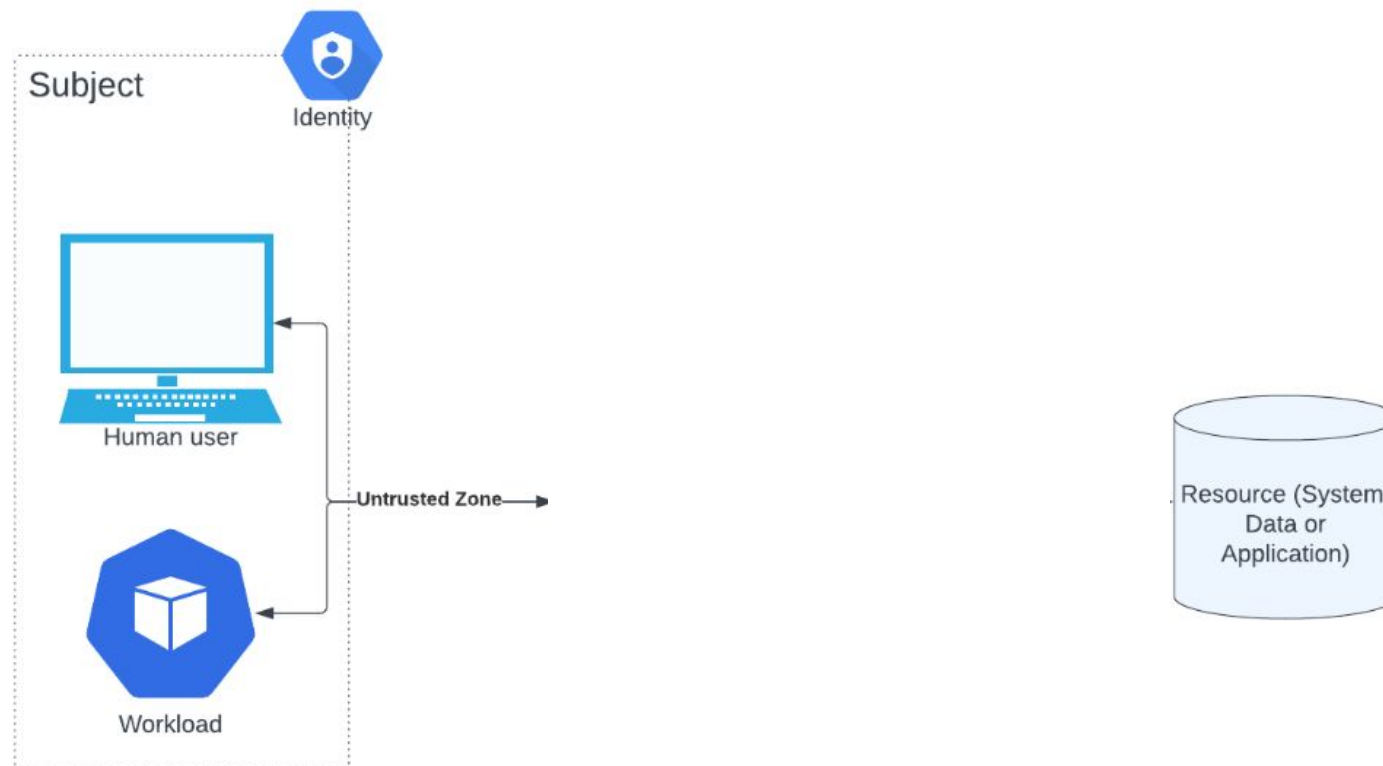
Zero trust – General thoughts

- Zero Trust is not a single architecture, but a set of guiding principles (“tenets”)
- Basic assumption: Attacker is present in the network all the time
- Main goal is (higher) cybersecurity, eliminating lateral movement
- Often ZT is defined what it is NOT:
 - No perimeter only security
 - No implicit trust based on (network) location
 - No distinction between enterprise-owned or non-owned assets (e.g. cloud, devices)
 - Not about avoiding an attack

Terminology (1)

Subject: User, Application or Device

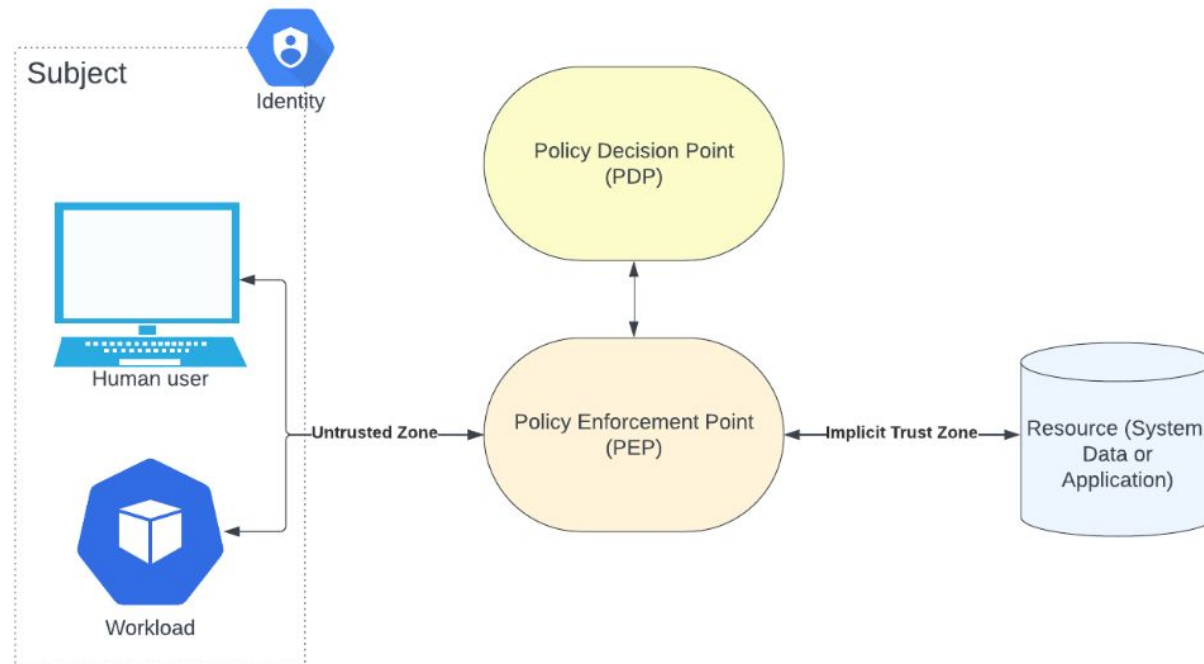
Resource: can be Data, but also Printers, Computer Resources, IoT actuators, etc



Terminology (2)

Policy Decision Point: The system entity that evaluates applicable policy and renders an authorization decision.

Policy Enforcement Point: The system entity that performs access control, by making decision requests and enforcing authorization decisions.



Tenets of Zero Trust

- All data sources and computing services are considered resources
- All communication is secured regardless of network location
- Access to individual enterprise resources is granted on a per-session basis
- Access to resources is determined by dynamic policy and may include other behavioral and environmental attributes
- The enterprise monitors and measures the integrity and security posture of all owned and associated resources
- All resource authentication and authorizations are dynamic and strictly enforced before access is allowed
- The enterprise collects as much information as possible about the current state of assets, network infrastructure and communications and uses it to secure its security posture

Challenges of Zero Trust

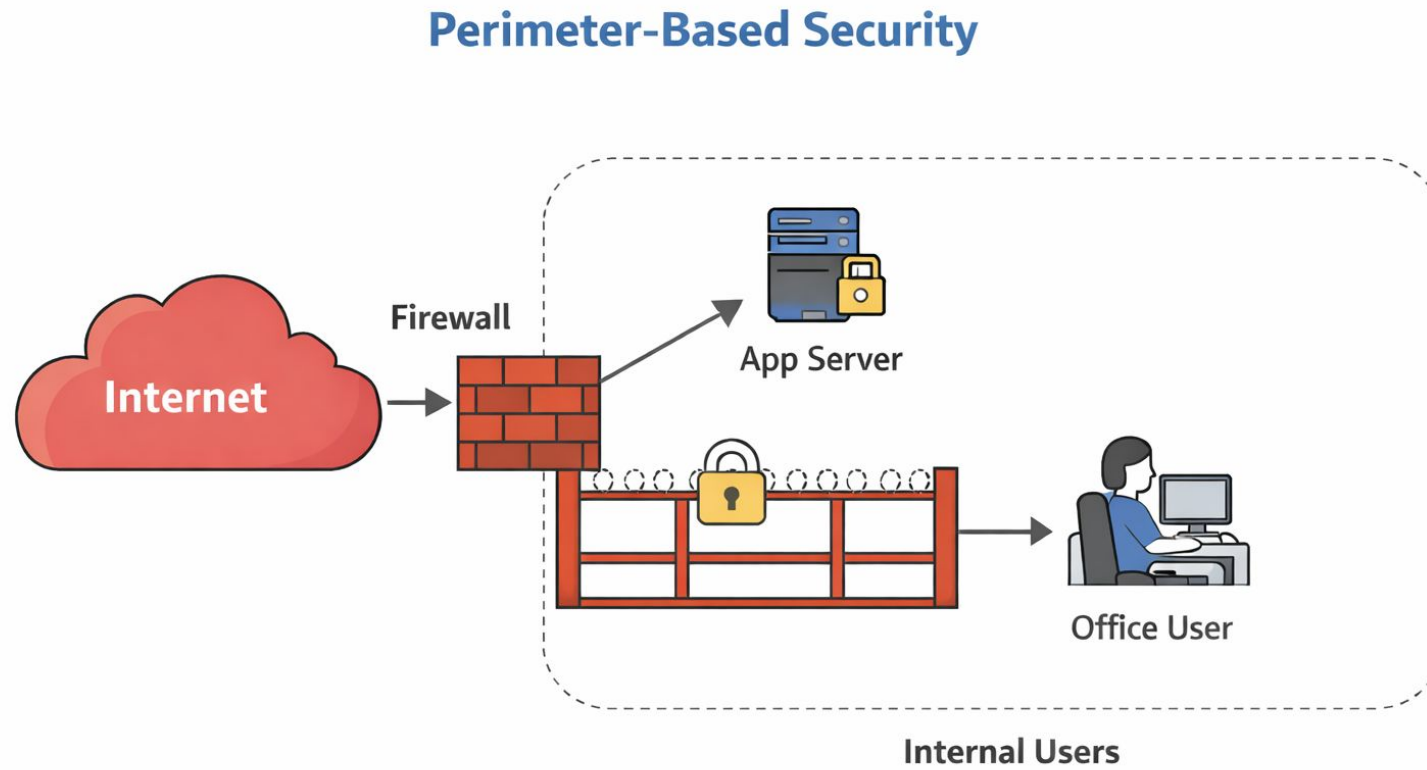
- The scope is both for non-enterprise subjects (e.g. visitors, customers,...) and non-enterprise-controlled infrastructures (BYOD, cloud)
- Balance of security vs usability (false positives, convenience, performance,...)
- Zero Trust introduces new critical components (e.g. PDP/PEP, IDP, PKI Infrastructure,...) - How are they secured? Authenticated? Resilient?
- How to deal with hybrid scenarios?

Common Approaches for Zero Trust Architecture¹

- (Perimeter-based security model)
- Micro-Segmentation
- Software Defined Perimeter
- Identity-based Governance

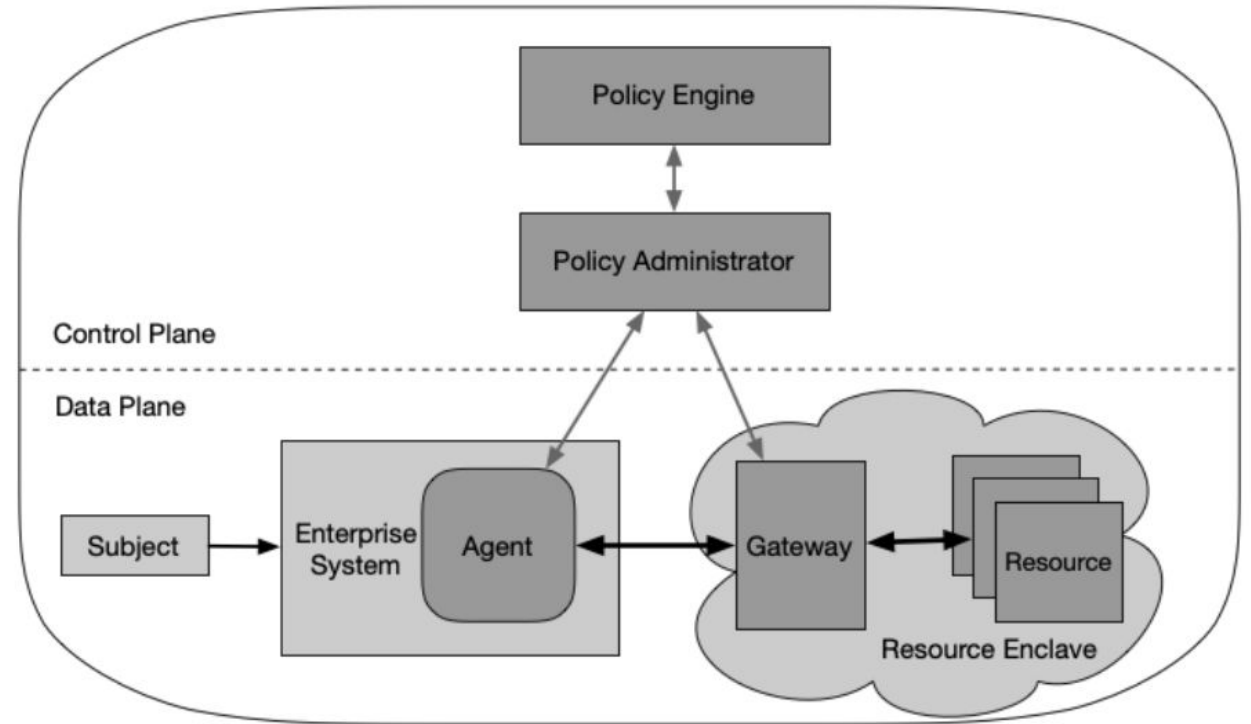
¹ A perimeter-based security model with a traditional firewall is not seen as a valid approach for a Zero Trust Architecture

Perimeter-based Security



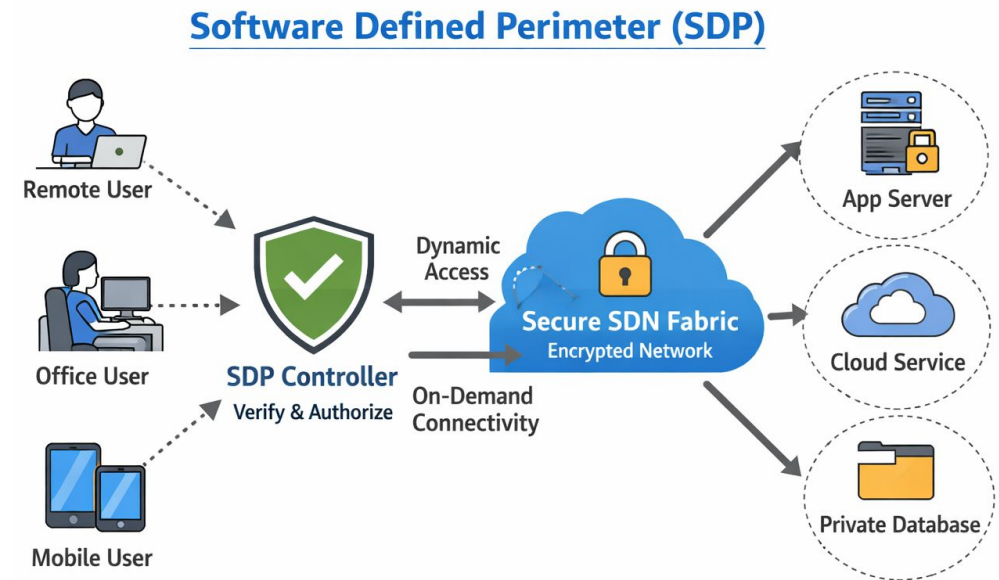
Common Approaches of ZT (1) - Micro-Segmentation

- Placing individual or group of resources on a unique network segment (aka "enclave")
- Protected by a gateway security component (e.g. Next generation fire walls)
- Optionally use software gateways on the resources ("agents")



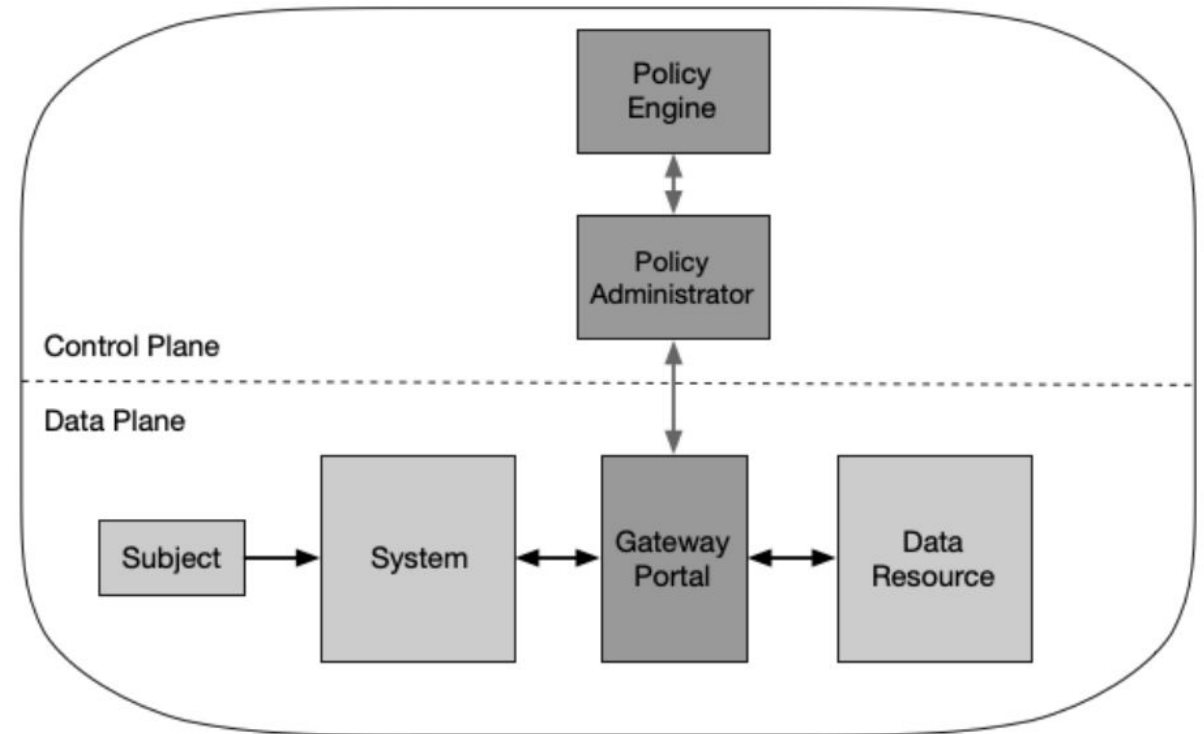
Common Approaches of ZT (2) - Software Defined Perimeter

- Based on the result of policy evaluation at the PDP, the software-defined network is (re)-configured
- "Need-to-know" model for resources
- Implemented via dynamic, encrypted tunnels



Common Approaches of ZT (3) - Identity-based Governance

- Network almost entirely open, flat
- Uses identity of subjects as the key component for policy creation
- Mostly used for heterogeneous environments (external users, contractors, BYOD)
- Downside: DoS attacks, easy network reconnaissance



Mental model - comparison

- ▶ Perimeter with Firewalls: Lock the front door
- ▶ Micro-segmentation: Lock each room inside the building so intruders can't wander
- ▶ Software-Defined Perimeter: Hide rooms and only provide controlled pathways
- ▶ Identity-based Governance: Define what each person or service can do, and enforce it everywhere continuously

Questions?



[linkedin.com/company/red-hat](https://www.linkedin.com/company/red-hat)



[facebook.com/redhatinc](https://www.facebook.com/redhatinc)



[youtube.com/user/RedHatVideos](https://www.youtube.com/user/RedHatVideos)



twitter.com/RedHat